

KEYUR AGHAO

kaghao@andrew.cmu.edu • 412-330-8935 • [linkedin.com/in/keyur-aghao](https://www.linkedin.com/in/keyur-aghao) • github.com/keyuraghao

SUMMARY

Application security engineer and MS Information Security candidate at Carnegie Mellon University (Dec 2026) focused on vulnerability research, code analysis, threat modeling, and custom security tooling across the application and system levels. Published the first public proof-of-concept for CVE-2025-20260 and owns findings from discovery through exploit validation and clear remediation guidance for engineering teams.

EDUCATION

Carnegie Mellon University

Master of Science in Information Security

Pittsburgh, PA

Jan 2025 - Dec 2026

Relevant Coursework: Hacking & Offensive Security, Mobile & IoT Security, Security of Networked Systems, Distributed Systems

Pune Institute of Computer Technology

Bachelor of Engineering in Electronics and Telecommunication

Pune, India

Jul 2019 - Apr 2023

ACHIEVEMENTS

Embedded CTF (eCTF) 2026 - 1st Place

Carnegie Mellon University

Ranked 1st internationally at MITRE's Embedded CTF (eCTF) 2026, defeating 100+ university teams through hardware fault-injection, side-channel analysis, and firmware exploitation techniques.

Microsoft Bug Bounty - 2 MSRC-Acknowledged Findings

Responsible Disclosure

Identified an Azure AD authentication race condition enabling token state manipulation under concurrent requests and a PowerShell execution policy bypass allowing unsigned script execution (ATT&CK T1059.001); both acknowledged by MSRC.

PROFESSIONAL EXPERIENCE

Bajaj Finance Ltd.

Pune, India

Security Engineer

May 2024 - Dec 2024

- Led application security assessments across the secure SDLC for 3 business units, performing threat modeling, secure design reviews, and vulnerability analysis that uncovered 60+ vulnerabilities aligned to OWASP, CWE, and MITRE ATT&CK.
- Built and deployed custom VAPT tooling that outperformed commercial scanners, saving ~\$1M annually and improving detection accuracy across monitored endpoints.
- Integrated SAST (Semgrep, CodeQL) and DAST (Burp Suite, OWASP ZAP) into CI/CD pipelines, blocking vulnerable builds pre-deployment and reducing post-release vulnerability discovery by 40%.
- Automated vulnerability triage and enrichment workflows in Python and translated findings into developer-actionable fixes, cutting manual handling by 39% and accelerating remediation SLAs.

Software Engineer

Jul 2023 - May 2024

- Executed application security testing across 500+ AI/ML systems and their web and API surfaces, identifying abuse paths including input manipulation and insecure API behaviors and validating exploitability through adversarial testing.
- Developed Python automation orchestrating vulnerability scanning, API testing, and result aggregation across distributed systems, cutting manual triage by ~30%.

API Governance & Application Security Intern

Jan 2023 - Jul 2023

- Performed API security testing across 4,000+ endpoints with Burp Suite and custom scripts, identifying authentication flaws, broken access control, and OWASP API Top 10 misconfigurations, and confirmed fixes with service owners.

KEY PROJECTS

CVE-2025-20260 Vulnerability Research & Coordinated Disclosure (CVSS 9.8)

2025

- Reverse engineered ClamAV's PDF parser, traced the mis-sized buffer allocation triggered by a crafted stream length, and published the first public proof-of-concept for the CVSS 9.8 buffer overflow.
- Built an exploit generator producing a malicious PDF whose ASCII85-decoded stream is just longer than uint32_MAX/4, forcing the mis-sized allocation and reliably triggering the overflow.
- Authored a PSIRT-grade report covering root-cause analysis, a core-dump analysis of the crash, and mitigation guidance (upgrade to the patched release), supporting coordinated disclosure.

DJI Drone Firmware & Protocol Security Research (CMU INI, advised by Prof. Patrick Tague)

2025 - 2026

- Decrypted a signed DJI firmware package with 4 recovered keys and extracted 2 SquashFS roots and a YAFFS2 volume using binwalk, unsquashfs, and Ghidra for static analysis of Linux userspace binaries.
- Identified 14 vulnerabilities (5 critical), including an empty root password hash, a login-free getty root shell, and unauthenticated writable FTP, and chained them into a fully remote root compromise now in responsible disclosure.
- Bypassed TrustManagerFactory certificate pinning in the DJI Fly Android app via a Zygote-level hook after decompiling the APK with JADX and dumping in-memory DEX on a rooted device, exposing firmware download endpoints in plaintext.

TECHNICAL SKILLS

Languages: Python, C, C++, Go, JavaScript, TypeScript, Bash, PowerShell, x86/x64 Assembly

Vulnerability Research: Fuzzing, Exploit Development, Memory-Corruption Analysis, Binary Analysis (IDA Pro, Frida)

Application Security: Secure Code Review, Attack Surface Analysis, DevSecOps, Dependency Scanning, CVSS

Open-Source Tooling: SubHunter, MSRF (Mobile/IoT SAST/DAST), Cloud Piercer (CSPM), Docker, GitHub Actions CI

Certifications: Cryptography and Network Security, CEHv11, CND, OSCP (In-Progress)